IAM Ticket IAM-0004: MFA Support: Lost Phone

AccessGuard Health – Healthcare IAM Operations Simulation

Ticket ID	IAM-0004
Related	Board task Activity 4 — MFA Support; Step 10 of the Entra ID hands-on (Invoke-HvmcMfaSupport.ps1)
Request type	MFA support: lost device (Microsoft Authenticator)
Priority	High (the user cannot sign in, and the lost phone could be used to approve sign-ins)
Status	Open (template)
Date	November 2026
Opened / closed	*[time opened]* / *[time closed]*
Requester	Dr. Sarah Chen, Physician, Doctors (fictional)
Approver	IT Security
Handled by	Sabitha S Karanavar (IT)
Employee	Sarah Chen (HVMC-1001), Doctors (fictional)

Request

Dr. Chen called the help desk: she lost her phone this morning and cannot approve Microsoft Authenticator sign-in requests. She needs access to the clinical apps for her shift and has a new phone ready.

Identity Verification

The caller's identity was confirmed before any change, because help-desk calls are a known way for attackers to take over accounts (for example, the 2023 MGM Resorts attack began with a call to the help desk).

Method	*[e.g. call-back to the phone number HR has on file]*
Result	*[confirmed / not confirmed]*

Systems and Account Changes

Item	Before	After
System	Microsoft Entra ID (HVMC tenant), security defaults on	Same
Username	sarah.chen	sarah.chen

Item	Before	After
Account state	Enabled	Enabled
MFA methods	*[from the Status run]*	*[from the Verify run]*
Sign-in sessions	Active, including on the lost phone	*[from the Reset run]*
Password	Unchanged	Unchanged (not part of an MFA reset)
Group and app access	SG-Doctors-EHR-RW and its apps	Unchanged

Actions Taken

- Ticket opened; recorded the before state of the account and its MFA methods (read-only Status run).
- Verified the caller's identity before any change: *[how identity was verified]*.
- Ran the reset as a dry run first and checked the plan.
- *[filled from the Reset run: time and result of each step]*
- Asked Dr. Chen to sign in and register her new phone on her Security info page; she did it herself.
- Ran the Verify check and reviewed the audit log, then closed the ticket.

Verification

Check	Expected	Result
identity verified before the reset	Yes	*[result]*
old MFA methods removed at reset	Yes	*[result]*
new MFA method registered after the reset	Yes	*[result]*
audit: admin deleted security info	Yes	*[result]*
audit: user registered security info	Yes	*[result]*
account still enabled	Yes	*[result]*

Resolution Notes

- Sessions were revoked first, so anyone holding the lost phone was signed out before the MFA method was removed.
- Only the MFA methods were removed; the password and the password-reset email were kept, so the user could sign in and register again straight away.
- The user registered the new phone herself; the help desk never handled her credentials.
- The Entra ID audit log records both the admin removal and the user's new registration, which is the evidence for this ticket.

Lessons learned

- A Temporary Access Pass (a time-limited, one-time code issued by the help desk after the identity check) would let the user register the new phone without relying on the password

alone. It is worth evaluating for HVMC's MFA-recovery process.
- The identity check is the most important control in this process: a reset without it would hand the account to an attacker.

Evidence

Evidence files are kept locally in step10_mfa_support/evidence (not on GitHub). Phone numbers and directory IDs are not shown.

[screenshot 01_status_before.png]

Figure 1: Before: Sarah's registered methods (Microsoft Authenticator on the old phone)

[screenshot 02_reset_dryrun.png]

Figure 2: Dry run: the planned steps, nothing changed

[screenshot 03_reset_apply.png]

Figure 3: Reset applied after the identity check: sessions revoked, Authenticator removed

[screenshot 04_reregister.png]

Figure 4: Sarah registers Microsoft Authenticator on her new phone (Security info page)

[screenshot 05_verify.png]

Figure 5: Verify: new method registered after the reset, audit trail, all checks passed

[screenshot 06_audit_portal.png]

Figure 6: Entra admin center: audit log entries for the removal and the new registration